

The background of the image features a dark blue gradient on the left, transitioning into a large, vibrant, abstract shape on the right. This shape is composed of overlapping curved segments in shades of orange, pink, and purple, creating a dynamic, modern aesthetic.

AWS re:Invent

NOV. 27 – DEC. 1, 2023 | LAS VEGAS, NV

SEC332

Comprehensive vulnerability management across your AWS environments

Scott Ward

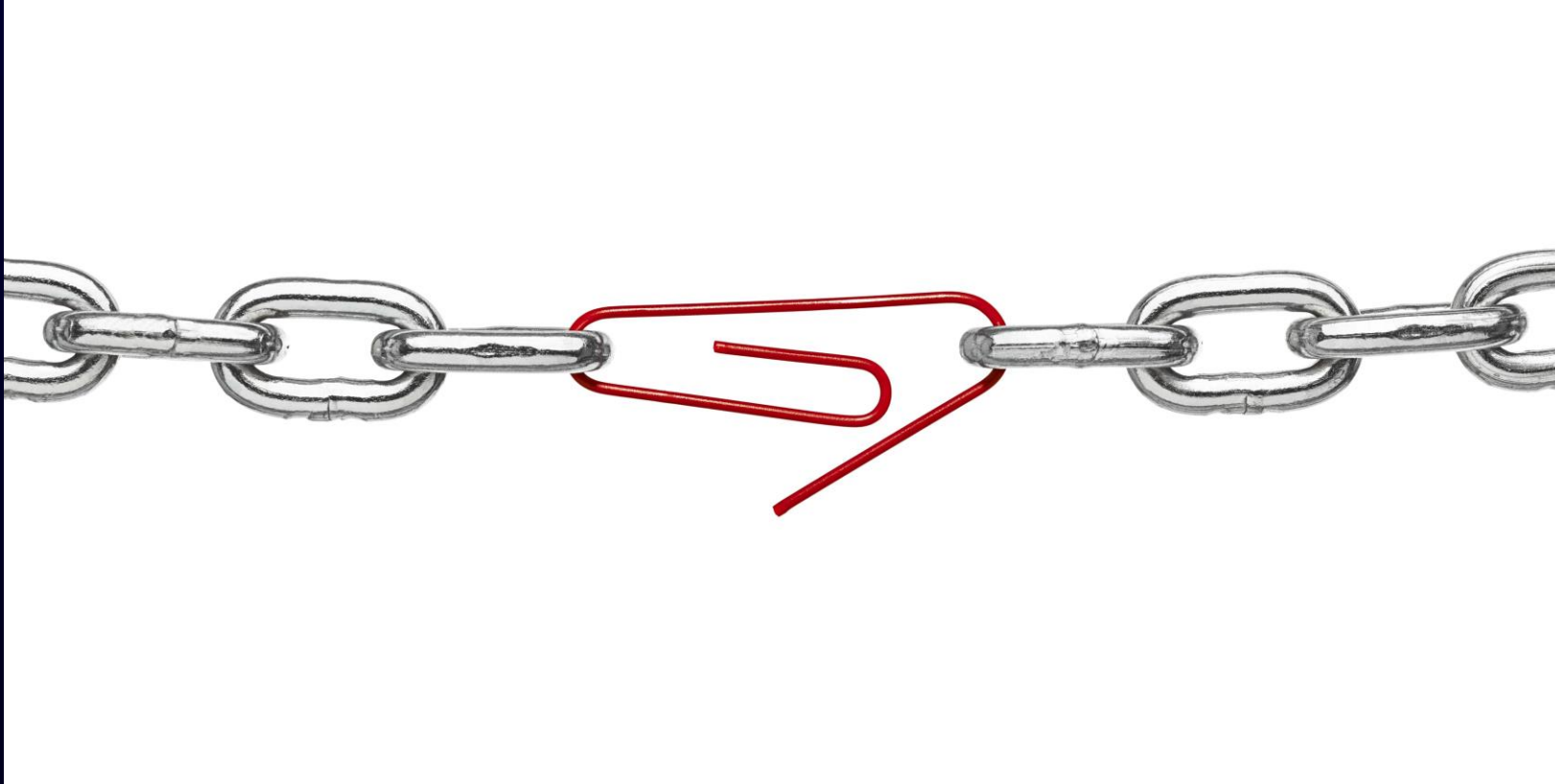
Principal Security Specialist SA
AWS

Megan O'Neil

Principal Security Specialist SA
AWS

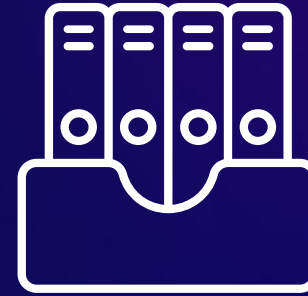


What is a vulnerability?



Vulnerabilities can be in multiple places

CVE – It's not just servers



CWE – It's your code



Mis-configuration – It's your resources



Where we are going to go today

- Resource coverage
- Visibility
- Vulnerability prioritization
- Modern methods

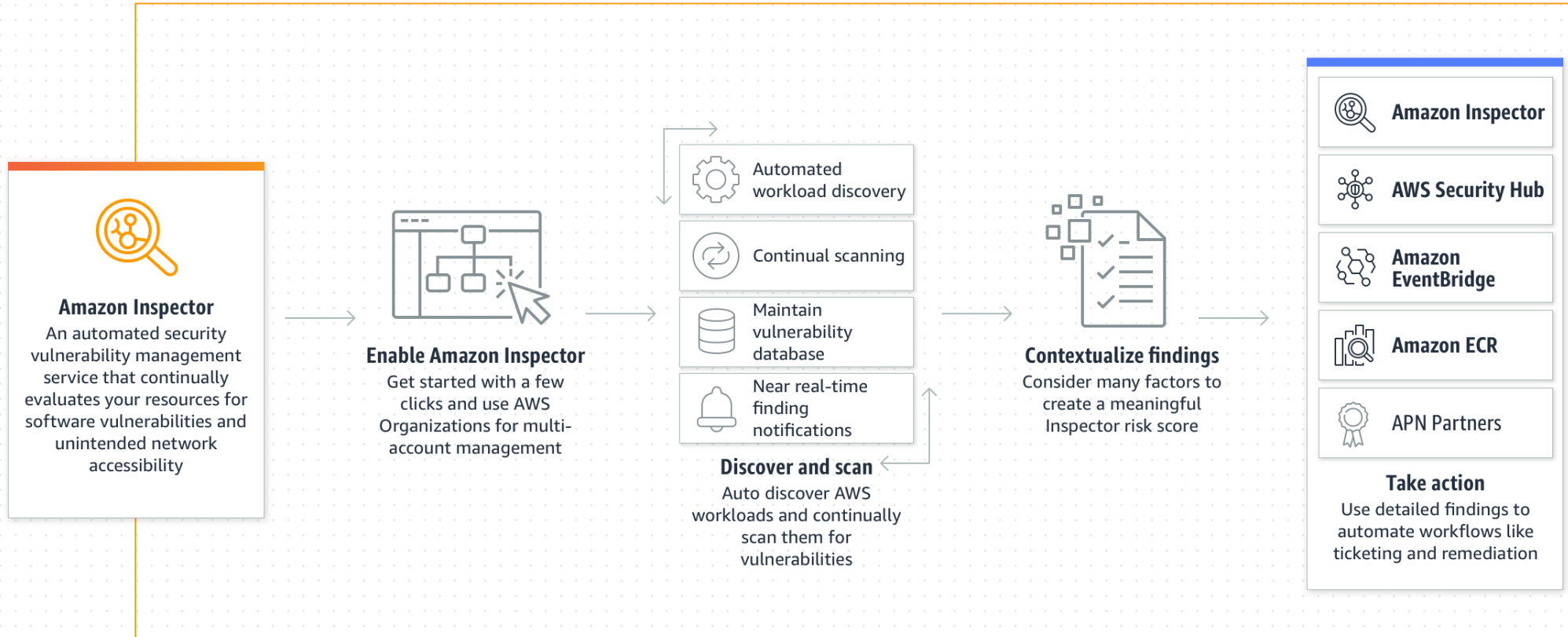
+ Demos along the way



Resource coverage

Overview of Amazon Inspector

AUTOMATED AND CONTINUAL VULNERABILITY MANAGEMENT AT SCALE



Overview of AWS Security Hub

AUTOMATED AND CONTINUAL VULNERABILITY MANAGEMENT AT SCALE



AWS Security Hub

Quickly assess your high-priority security alerts and security posture across all of your accounts and regions



Amazon GuardDuty



AWS Config



Amazon Inspector



AWS Firewall Manager



AWS Systems Manager



AWS IAM Access Analyzer



AWS Health



Amazon Macie

Integrated APN solutions

Continuously aggregate and prioritize

Findings from AWS and partner security services highlight emerging trends or possible issues



Conduct automated security checks

Run security best practice configuration checks with AWS Foundational Security Best Practices standard and other industry benchmarks, such as CIS and PCI



Take action

Investigate findings and/or take response and remediation actions

Virtual machines

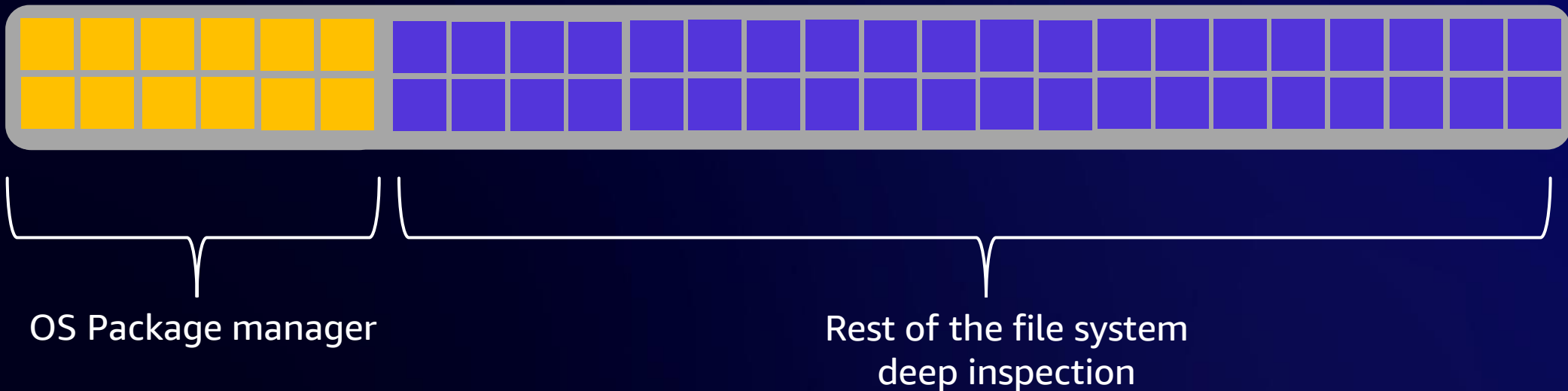
AMAZON INSPECTOR

Operating system package manager

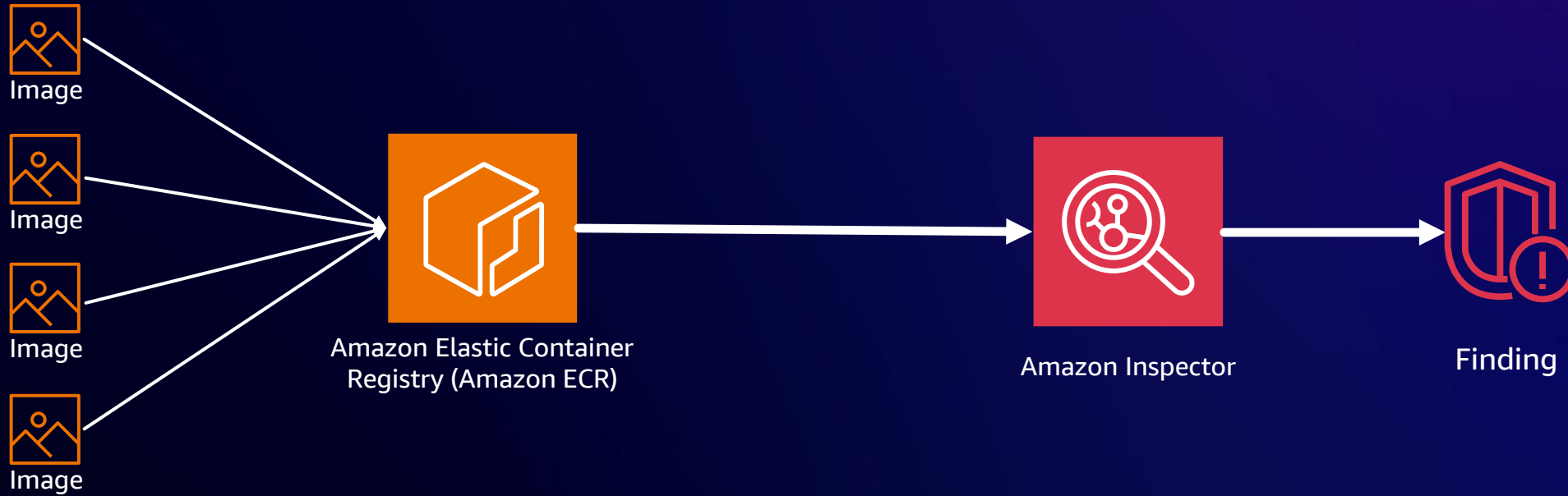


Agentless Scanning

What about all the code that might be on the machine that is not part of the package manager?
Deep inspection

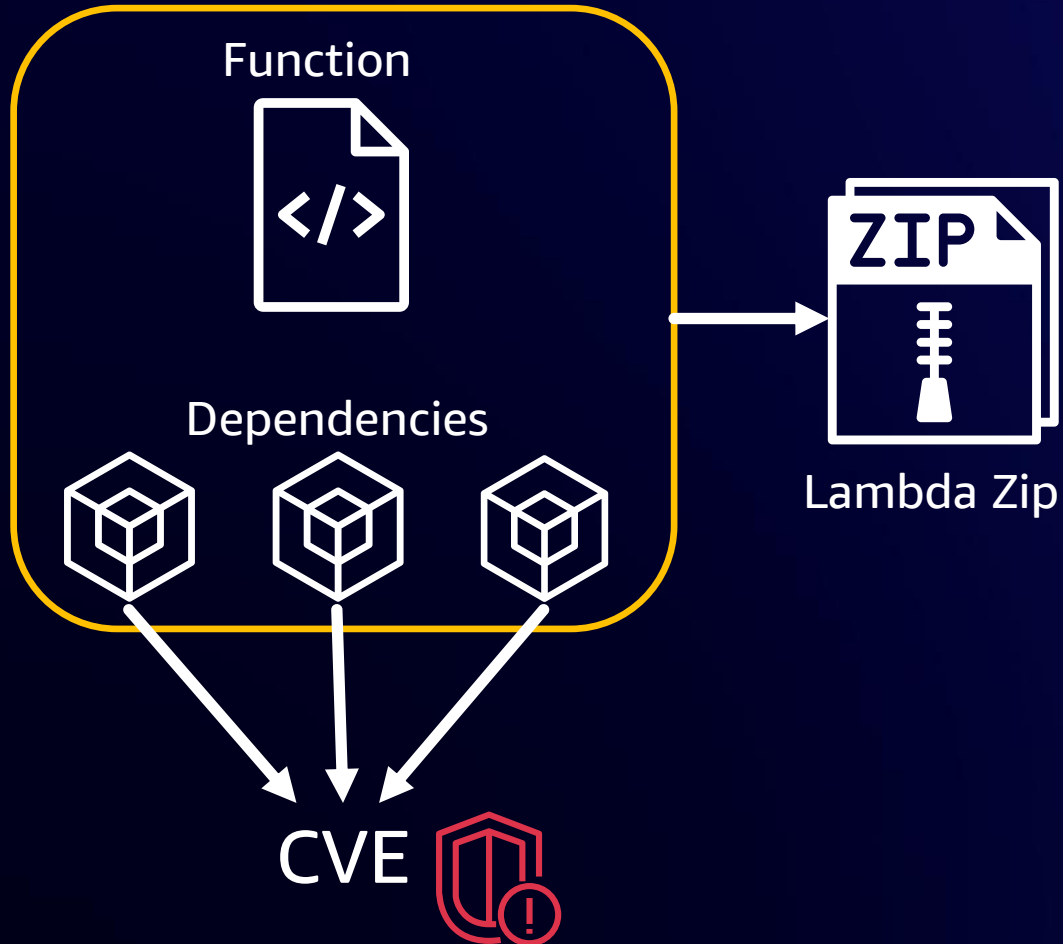


Container images

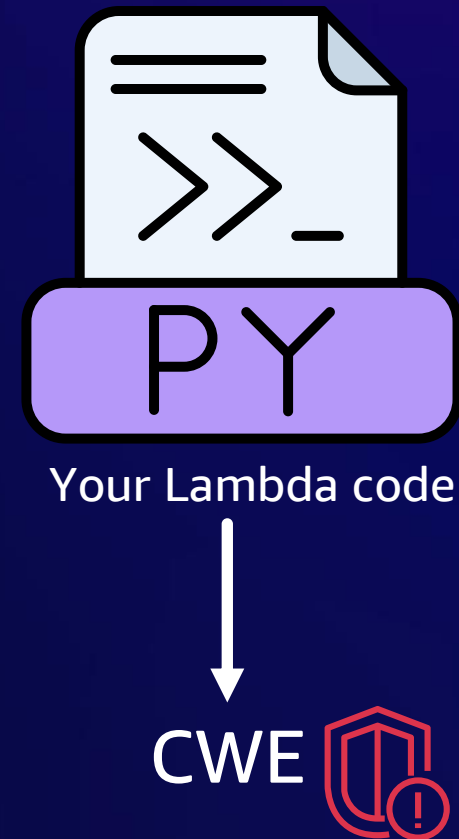


AWS Lambda functions

Lambda function dependencies – SCA



Lambda code vulnerabilities – SAST



Software bill of materials (SBOM)

Inventory of all the open source and third-party software components of your codebase

Gain visibility into your software supply

Most commonly used packages

Associated vulnerabilities across your organization

```
{
  "type": "application",
  "name": "libatspi2.0-0",
  "purl": "pkg:dpkg/libatspi2.0-0@2.22.0-6+deb9u1?arch=AMD64&epoch=0&upstream=libatspi2.0-0-2.22.0-6+deb9u1.src.dpkg",
  "version": "2.22.0",
  "bom-ref": "493680b1baca1a549472bf009f50d53b"
},
{
  "type": "library",
  "name": "org.springframework.cloud:spring-cloud-commons",
  "purl": "pkg:maven/org.springframework.cloud:spring-cloud-commons@1.1.0.BUILD-SNAPSHOT",
  "version": "1.1.0.BUILD-SNAPSHOT",
  "properties": [
    {
      "name": "amazon:inspector:path",
      "value": "src/target/cve20164977-0.0.1-SNAPSHOT.jar"
    }
  ],
  "bom-ref": "11afb89bbfd3173d9bdd2100d2940c84"
},
```

Control plane AWS resources

AWS SECURITY HUB



Services currently covered

AWS CloudFormation
AWS Identity and Access Management (IAM)
AWS Config
Amazon Redshift
Amazon Simple Notification Service (Amazon SNS)
AWS Certificate Manager (ACM)
AWS Secrets Manager
Amazon CloudFront
AWS Database Migration Service (AWS DMS)
Amazon GuardDuty
Amazon Relational Database Service (Amazon RDS)
AWS Lambda
AWS Firewall Manager
Amazon API Gateway
Amazon EMR
AWS CloudTrail
Amazon CloudWatch
AWS AppSync
Amazon Elastic Kubernetes Service (EKS)
Amazon ElastiCache
Amazon Managed Streaming for Apache Kafka (MSK)
AWS Network Firewall
Amazon Simple Queue Service (SQS)

Amazon Simple Storage Service (Amazon S3)
Amazon DocumentDB (with MongoDB compatibility)
AWS WAF
Amazon Elastic Container Registry (Amazon ECR)
Amazon Elastic Container Service (Amazon ECS)
Amazon Athena
Amazon Kinesis
Amazon SageMaker
Amazon EC2 Auto Scaling
Amazon Neptune
AWS Systems Manager
Amazon Elastic File System (Amazon EFS)
AWS CodeBuild
AWS Key Management Service (AWS KMS)
Amazon Elastic Compute Cloud (Amazon EC2)
Amazon DynamoDB
AWS Elastic Beanstalk
Elastic Load Balancing
Amazon OpenSearch Service
Amazon EventBridge
Amazon MQ
Amazon Route 53
AWS Step Functions

All of this is continuous



Amazon Inspector

Whenever you make a change to your Amazon EC2 inventory

Whenever you make a change to your Lambda function

Whenever the inspector vulnerability database is updated

AWS Security Hub

Change-based – whenever you make a change to a resource

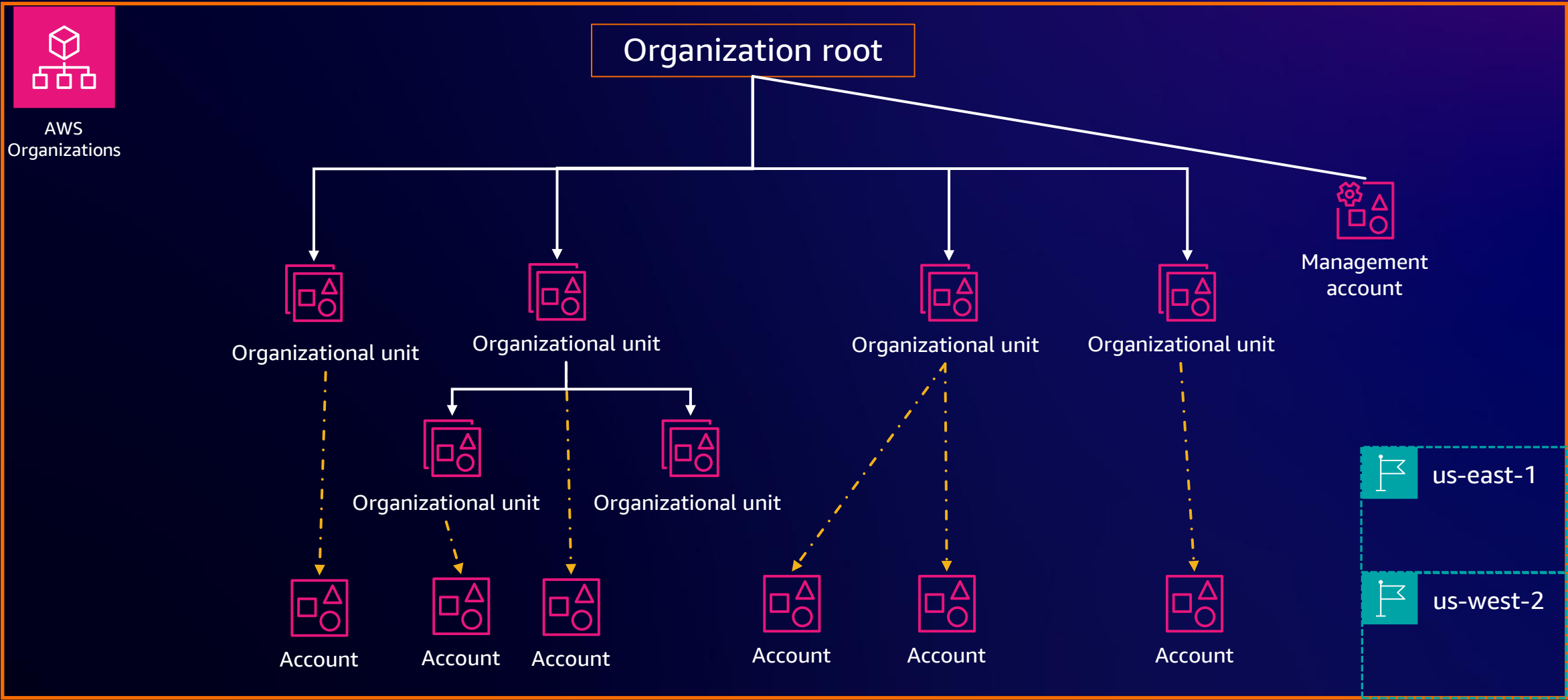
Periodic – check configuration every 12 hours

Visibility



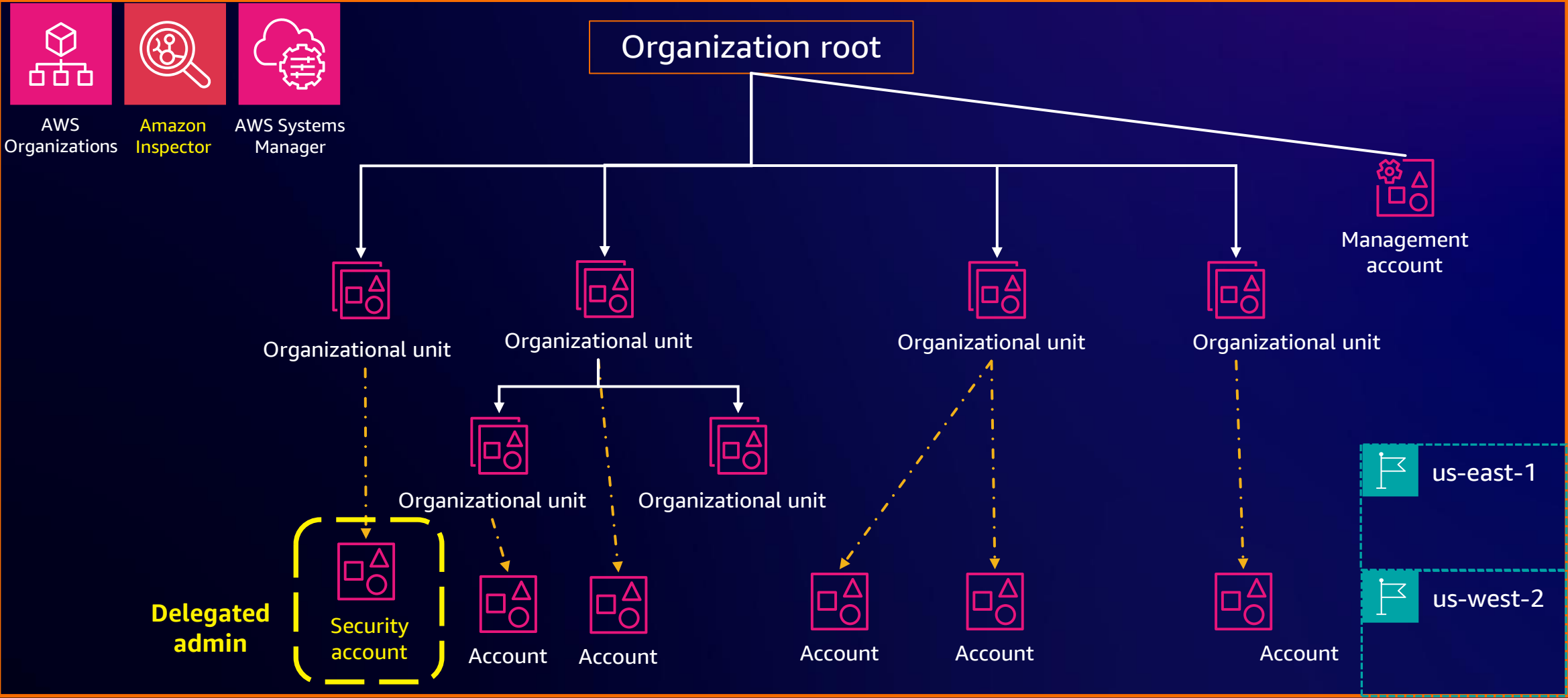
Visibility

AWS ORGANIZATIONS



Visibility

AWS ORGANIZATIONS



Configure

AMAZON INSPECTOR

Account name ▼	Status ▼	Amazon EC2 scanning ▼	Amazon ECR scanning ▼	AWS Lambda scanning ▼
megoneil-security-account	✔ Activated	✔ Activated	✔ Activated	✔ Activated standard scan (Deactivated code scan)
megoneil-mgmt	✔ Activated	✔ Activated	✔ Activated	✔ Activated (standard + code)
megoneil-lab	✔ Activated	✔ Activated	✔ Activated	✔ Activated (standard + code)
Demo-PCI	✔ Activated	✔ Activated	✔ Activated	✔ Activated (standard + code)



Configure

AMAZON INSPECTOR

Account name ▼	Status ▼	Amazon EC2 scanning ▼	Amazon ECR scanning ▼	AWS Lambda scanning ▼
megoneil-security-account	✔ Activated	✔ Activated	✔ Activated	✔ Activated standard scan (Deactivated code scan)
megoneil-mgmt	✔ Activated	✔ Activated	✔ Activated	✔ Activated (standard + code)
megoneil-lab	✔ Activated	✔ Activated	✔ Activated	✔ Activated (standard + code)
Demo-PCI	✔ Activated	✔ Activated	✔ Activated	✔ Activated (standard + code)



Configure

AMAZON INSPECTOR

Environment coverage

Your accounts, instances, and repositories that are activated with Inspector.

Accounts

100%

5 / 5 accounts

Instances

50%

6 / 12 instances

Repositories

100%

4 / 4 repositories

Lambda functions

90%

9 / 10 Lambda functions



Amazon EC2 coverage

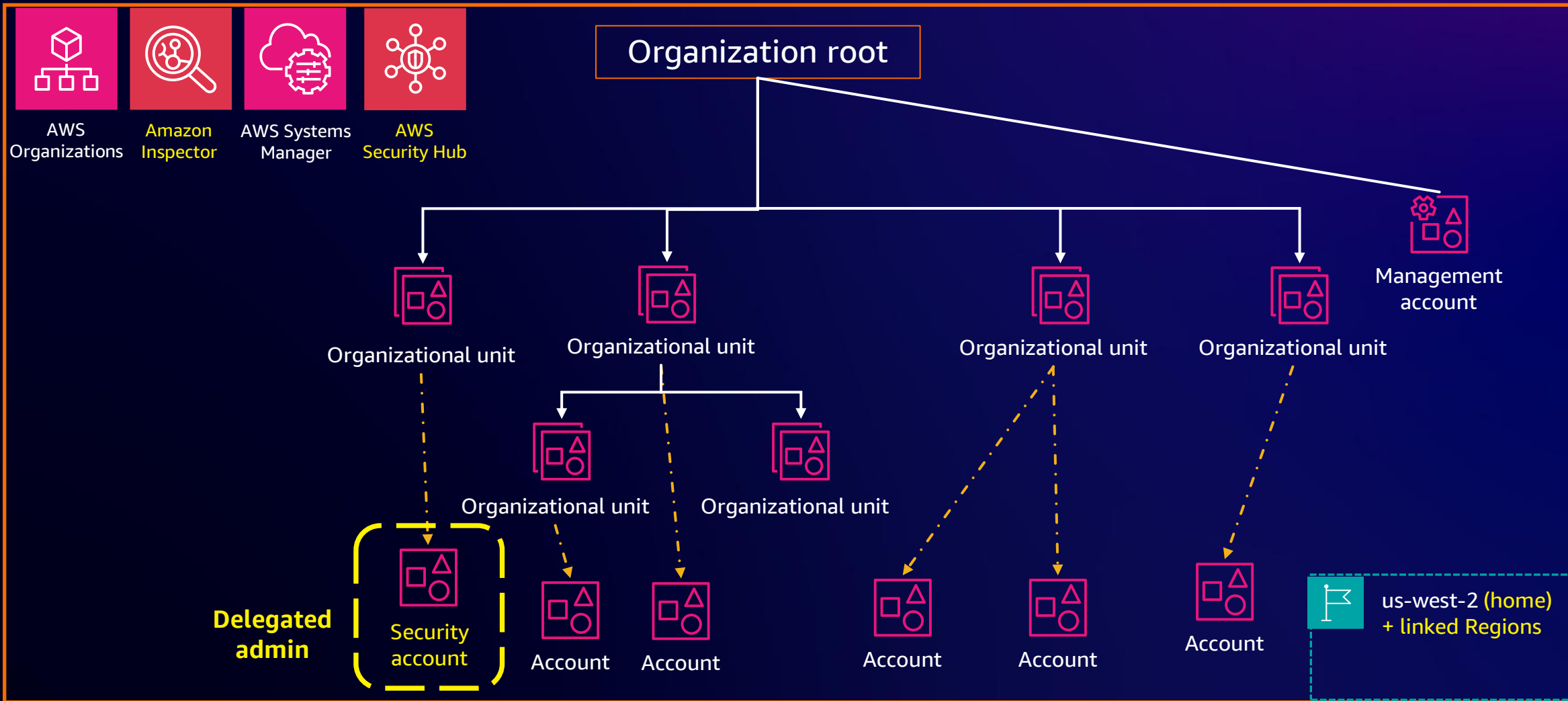
AMAZON INSPECTOR

EC2 instance	EC2 instance tags	Account	AMI	Operating...	Last scanned	Status
i-001119d24b364...	AWSWorkshop-Application:Ord...	megoneil-mgmt (111111111111)	ami-0d52d...	LINUX	November 22, 202...	Actively monitoring
i-00acd05ae85345...	AWSWorkshop-Application:Bil...	megoneil-mgmt (111111111111)	ami-0d52d...	LINUX	November 22, 202...	Actively monitoring
i-00e75c292e9e81...	AWSWorkshop-Application:Bil...	megoneil-mgmt (111111111111)	ami-0d52d...	LINUX	November 22, 202...	Actively monitoring
i-0119fe543f9abfafe	Name:RDS-jump	megoneil-security-account (666666666666)	ami-04a0ae...	UNKNOWN	-	Unmanaged EC2 instance
i-04ad0dc09c37c4...	Name:BTC Miner	megoneil-lab (222222222222)	ami-06eece...	UNKNOWN	-	EC2 instance stopped



Configure

AWS SECURITY HUB



Global configuration

AWS SECURITY HUB

NEW!



Centralize

With central configuration, the delegated administrator account can set a home Region and linked Regions to specify where configuration policies will apply.



Configure

Create configuration policies to manage and customize multiple Security Hub settings. Apply the policy to your entire organization or to specific accounts and organizational units (OUs).



Manage

Manage your policies as your organization evolves. You can create new policies and edit existing policies to provide appropriate security coverage for all of the accounts in your organization.

Console Home

EC2

S3

Athena

Security Hub

Amazon EventBridge

Step Functions

CloudFormation

Amazon Inspector

CloudWatch

Security Hub

Summary

Controls

Security standards

Insights

Findings

Integrations

Management

Automations

Custom actions

Settings

General

Regions

Configuration

Usage

What's new

Security Hub > Summary

Regions: All Linked Regions

Reset to default layout

+ Add widget

Choose a filter set

Filter data

Workflow status = NEW

Workflow status = NOTIFIED

Record state = ACTIVE

Clear filters

Security standards

Track your cloud security posture with a summary security score and standard security scores. This widget always shows complete, unfiltered data.

Security score

60%

Standard	Passed	Failed	Score
AWS Foundational Security Best Practices v1.0.0	141	94	60%
CIS AWS Foundations Benchmark v1.2.0			Enable
CIS AWS Foundations Benchmark v1.4.0			Enable
NIST Special Publication 800-53 Revision 5			Enable
PCI DSS v3.2.1			Enable

View all standards

Assets with the most findings

Prioritize and evaluate your assets that are most at risk.

Resources

Accounts

Applications

Resources	By severity	By resource type	Total findings
arn:aws:ec2:us-east-1:111111111111:instance/i-00acd05ae85345dfc			199
arn:aws:ec2:us-east-1:111111111111:instance/i-00e75c292e9e8124e			197
arn:aws:ec2:us-east-1:111111111111:instance/i-0bcde1778b40ce724			197
arn:aws:ec2:us-east-1:111111111111:instance/i-00000000000000000			197

View Insight

CloudShell

Feedback

© 2023, Amazon Web Services, Inc. or its affiliates. Privacy Terms Cookie preferences

Vulnerability prioritization

Amazon Inspector details

PRIORITIZATION: CVE-2018-25014 — LIBWEBP

Finding overview	
AWS account ID	
Severity	High
Type	Package Vulnerability
Fix available	Yes
Last known public exploit at	-
Exploit available	No
Created at	August 10, 2023 11:28 AM (UTC-06:00)
Affected packages	
Name	libwebp
Installed version / Fixed version	<u>0:0.3.0-10.amzn2.0.1.X86_64</u> / 0:0.3.0-10.amzn2.0.2
Package manager	OS
Remediation	
Upgrade your installed software packages to the proposed fixed in version and release.	
yum update libwebp	

Amazon Inspector details

PRIORITIZATION: CVE-2018-25014 — LIBWEBP

Finding overview	
AWS account ID	
Severity	High
Type	Package Vulnerability
Fix available	Yes
Last known public exploit at	-
Exploit available	No
Created at	August 10, 2023 11:28 AM (UTC-06:00)
Affected packages	
Name	libwebp
Installed version / Fixed version	0:0.3.0-10.amzn2.0.1.X86_64 / 0:0.3.0-10.amzn2.0.2
Package manager	OS
Remediation	
Upgrade your installed software packages to the proposed fixed in version and release.	
yum update libwebp	

Vulnerability details	
Vulnerability ID	CVE-2018-25014 ↗
Vulnerability source	AMAZON_CVE
CWEs	CWE-908 ↗
Inspector score	8.4
Inspector scoring vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H...
Exploit Prediction Scoring System (EPSS)	0.00212
CVSS 3.1	9.8 (Source: AMAZON_CVE)
Scoring vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVSS 3.1	9.8 (Source: NVD)
Scoring vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVSS 2.0	7.5 (Source: NVD)
Scoring vector	AV:N/AC:L/Au:N/C:P/I:P/A:P

Amazon Inspector details

PRIORITIZATION: CVE-2018-25014 — LIBWEBP

Finding overview	
AWS account ID	
Severity	High
Type	Package Vulnerability
Fix available	Yes
Last known public exploit at	-
Exploit available	No
Created at	August 10, 2023 11:28 AM (UTC-06:00)
Affected packages	
Name	libwebp
Installed version / Fixed version	0:0.3.0-10.amzn2.0.1.X86_64 / 0:0.3.0-10.amzn2.0.2
Package manager	OS
Remediation	
Upgrade your installed software packages to the proposed fixed in version and release.	
yum update libwebp	

Vulnerability details	
Vulnerability ID	CVE-2018-25014
Vulnerability source	AMAZON_CVE
CWEs	CWE-908
Inspector score	8.4
Inspector scoring vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H...
Exploit Prediction Scoring System (EPSS)	0.00212
CVSS 3.1	9.8 (Source: AMAZON_CVE)
Scoring vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVSS 3.1	9.8 (Source: NVD)
Scoring vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVSS 2.0	7.5 (Source: NVD)
Scoring vector	AV:N/AC:L/Au:N/C:P/I:P/A:P

Amazon Inspector details

PRIORITIZATION: CVE-2018-25014 — LIBWEBP

Tags	
AWSWorkshop-Application	Billing
AWSWorkshop-ApplicationTier	Database
AWSWorkshop-CostCenter	300
AWSWorkshop-Department	Finance
AWSWorkshop-Environment	Staging
aws:cloudformation:logical-id	DBServer1
aws:cloudformation:stack-id	arn:aws:cloudformation:us-east-1: [REDACTED] ...
aws:cloudformation:stack-name	FirewallMgrLabStack



Amazon Inspector intelligence

PRIORITIZATION

CVSS v3 (AMAZON_CVE)		Inspector
9.8		8.4
The Inspector score is lower . Changed metrics: Attack Vector		
CVSS score metrics		
Metric	CVSS	Inspector
Attack Vector	Network	 ⓘ Local
Attack Complexity	Low	Low
Privileges Required	None	None
User Interaction	None	None
Scope	Unchanged	Unchanged
Confidentiality	High	High
Integrity	High	High
Availability	High	High



Amazon Inspector intelligence

PRIORITIZATION

CVSS v3 (AMAZON_CVE)		Inspector
→ 9.8		→ 8.4
The Inspector score is lower . Changed metrics: Attack Vector		
CVSS score metrics		
Metric	CVSS	Inspector
Attack Vector	Network	Local
Attack Complexity	Low	Low
Privileges Required	None	None
User Interaction	None	None
Scope	Unchanged	Unchanged
Confidentiality	High	High
Integrity	High	High
Availability	High	High



Amazon Inspector intelligence

PRIORITIZATION

CVSS v3 (AMAZON_CVE)		Inspector
→ 9.8		→ 8.4
The Inspector score is lower . Changed metrics: Attack Vector		
CVSS score metrics		
Metric	CVSS	Inspector
Attack Vector	Network	Local
Attack Complexity	Low	Low
Privileges Required	None	None
User Interaction	None	None
Scope	Unchanged	Unchanged
Confidentiality	High	High
Integrity	High	High
Availability	High	High

Vulnerability intelligence

ATT&CK®

Techniques [T1587.004, T1588.001, and 6 more](#)

CISA

Added date -

Due date -

Action -

Known malware

Malware **Pegasus**

Evidence

Evidence rule [Historically Linked to Penetration Testing Tools](#)

Severity Low

Evidence rule [Historically Linked to Malware](#)

Severity Low

Vulnerability intelligence enriched with **Recorded Future** [↗](#)



Amazon Inspector intelligence

PRIORITIZATION

Known malware

Malware Pegasus

Evidence

Historically Linked to Penetration Testing Tools

6 sightings on 1 source: Tenable. Most recent link (Nov 12, 2021): <https://www.tenable.com/plugins/nessus/155205>

Historically Linked to Penetration Testing Tools

Low

Historically Linked to Malware

Low

Vulnerability intelligence enriched with

Action -

Known malware

Malware Pegasus

Evidence

Evidence rule Historically Linked to Penetration Testing Tools

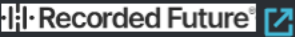
Severity Low

Evidence rule Historically Linked to Malware

Severity Low

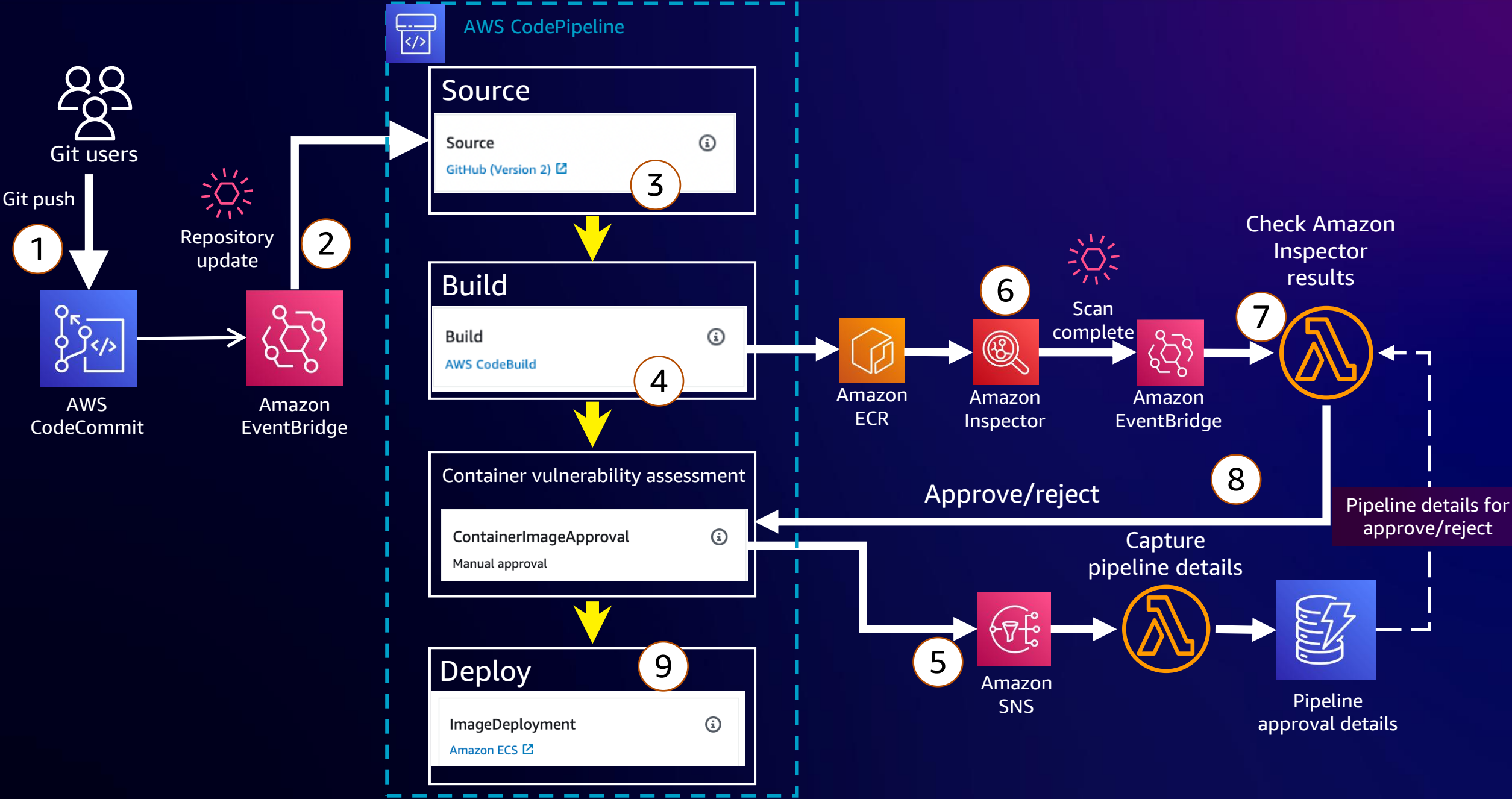
Historically Linked to Malware

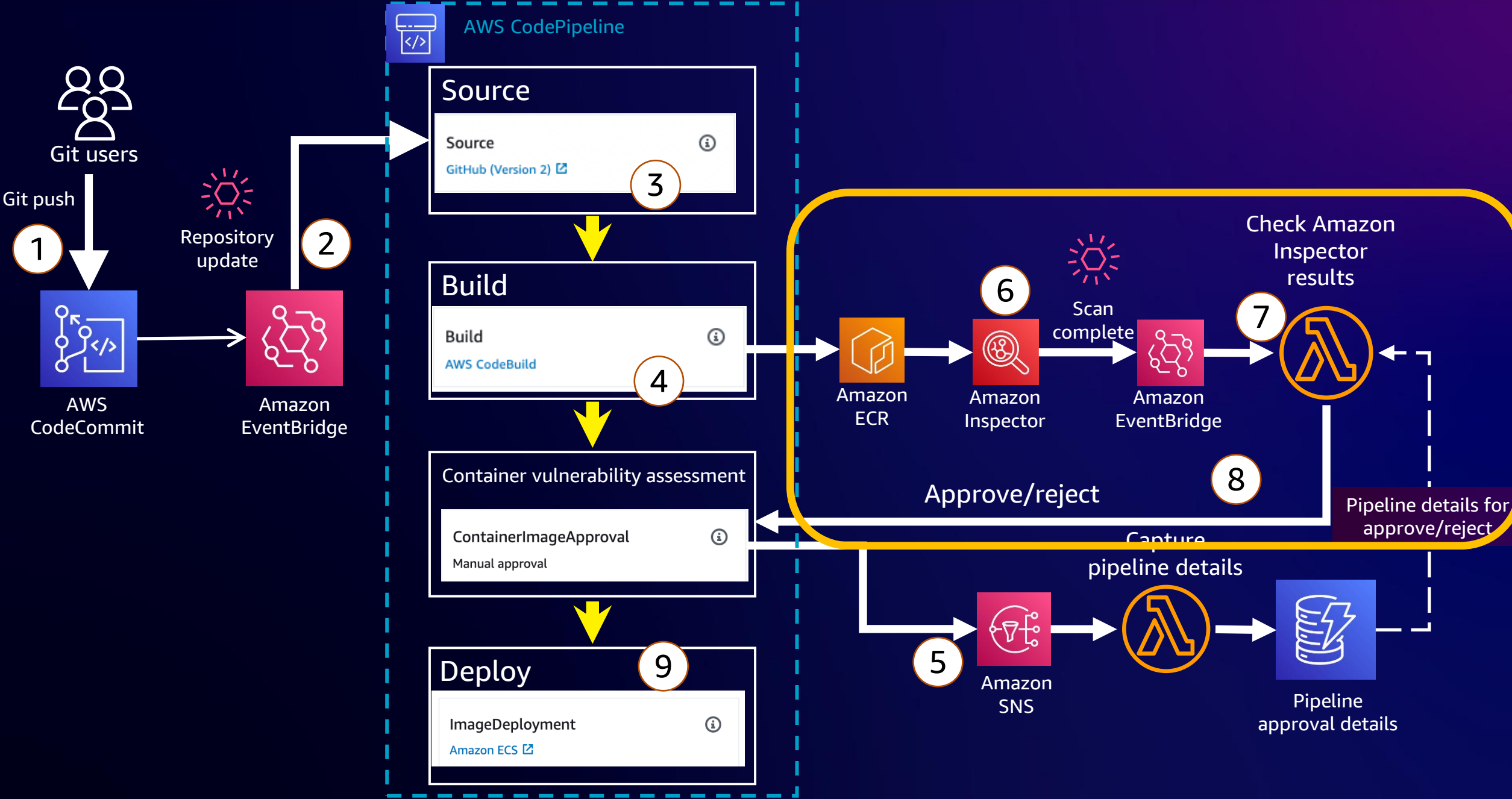
13 sightings on 7 sources including: usnews18.com, fook.news, paper.li, secoperations.pt, WCCFtechcom. 2 related malware families: Pegasus, Spyware. Most recent link (Jul 26, 2021): <https://wccfttech.com/ios-14-7-1-addresses-a-zero-day-bug/>

Vulnerability intelligence enriched with 



Modern methods





Resources

AWS Security Blog: Building a scalable vulnerability management program on AWS



AWS Security Blog: Use Amazon Inspector to manage your build and deploy pipelines for containerized applications



Save the date for AWS re:Inforce

JUNE 10 - 12, 2024 | PHILADELPHIA, PA



AWS
re:Inforce



© 2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Thank you!



Please complete the session
survey in the mobile app